

Security+ 2.3 · Supply Chain Vulnerabilities

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — Supply Chain Vulnerabilities (9:12)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Supply chain vulnerabilities attack a trusted link: compromised software (SolarWinds), third-party components, malicious hardware chips, code libraries (npm/pip), or open-source packages with unclear ownership. The attacker injects code into the TRUSTED CHANNEL — everyone who downloads it spreads it for them. Defenses: SBOM (ingredient list), code signing, SCA (checks library vulnerabilities), source verification.

High-Yield Core Concepts Tested on Exam

- Supply chain: attacker uses the TRUSTED CHANNEL to enter
- SolarWinds: the classic case (18k companies affected)
- SBOM = Software Bill of Materials — list of software components
- SCA scans dependencies for known vulnerabilities
- Code signing verifies software integrity and origin

Exam Tips & Classic Scenarios

- 'list of software components' = SBOM
- 'checks dependencies for known vulnerabilities' = SCA
- 'compromised npm library affects all users' = supply chain vulnerability

Typical Exam Scenario: Scenario: 'a compromised npm library affects everyone using the package' = supply chain vulnerability.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Supply Chain Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Compromising a software vendor to reach all of its customers (e.g., SolarWinds):

- A)** Supply chain attack
- B)** Watering hole
- C)** Insider
- D)** Zero-day

2. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Supply chain: the attacker uses the TRUSTED CHANNEL to enter'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Supply chain: the attacker uses the TRUSTED CHANNEL to enter...

3. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SolarWinds: the classic case (18k companies)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: SolarWinds: the classic case (18k companies)...

4. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SBOM = Software Bill of Materials — list of software components.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: SBOM = Software Bill of Materials — list of software components...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'list of software components' = SBOM'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'list of software components' = SBOM...

6. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'checks dependencies for known vulnerabilities' = SCA. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'checks dependencies for known vulnerabilities' = SCA.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: compromised npm library affects everyone using the package' = supply chain vulnerability. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: compromised npm library affects everyone using the package = supply chain vulnerability...
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 2.3) exam, an analyst evaluates the following technical requirement: 'Supply chain: the attacker uses the TRUSTED CHANNEL to get in'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Supply chain: the attacker uses the TRUSTED CHANNEL to get in...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SolarWinds: the classic case (18k companies)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: SolarWinds: the classic case (18k companies)...
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (Supply Chain Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SBOM = Software Bill of Materials — list of software components.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: SBOM = Software Bill of Materials — list of software components.

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Supply chain attack.

✓ **Why it is correct:** A supply chain attack occurs when an adversary compromises a vendor, partner, or software/hardware component to reach the end customers of that vendor. In the SolarWinds case (2020), attackers compromised the build process of the Orion software, inserting malicious code that was distributed as a legitimate update to thousands of customers, including government agencies. This is the classic example of a supply chain attack, as described in SY0-701 objective 2.2 (supply chain threats) and 2.3 (attack vectors). The question describes exactly this scenario: compromising a software vendor to reach all of its customers.

✗ **Why the others are wrong:**

- *Watering hole:* A watering hole is an attack in which the adversary compromises a legitimate website frequented by a specific group of victims (e.g., an industrial sector site) and inserts malicious code to infect visitors. The goal is to reach users who visit that site, not to compromise a software vendor to distribute malware to all its customers. In a watering hole, the vector is the third-party site visited by victims; in a supply chain attack, the vector is the vendor's own product or update. The question speaks of compromising a software vendor to reach all its customers, which is supply chain, not watering hole.
- *Insider:* An insider threat refers to an individual with authorized access (employee, contractor, partner) who uses that access to cause harm, steal data, or facilitate attacks. The attacker is internal to the organization, not a compromised external vendor. In the SolarWinds case, the attackers were external (APT29) who compromised SolarWinds' supply chain; it is not an insider of SolarWinds or its customers. Therefore, insider does not describe the scenario of compromising a vendor to reach its customers.
- *Zero-day:* A zero-day refers to a vulnerability unknown to the vendor, for which no patch is available. The attack exploits this flaw before it is fixed. Although supply chain attacks may involve zero-days, the concept of zero-day is about the nature of the vulnerability, not about the vector of compromising a vendor to reach customers. In the SolarWinds case, the attack did not rely exclusively on a zero-day; it involved compromising the build process and distributing a malicious update. The question asks for the name of the attack that compromises a vendor to reach all customers, which is supply chain, not zero-day.

2) D — Implement the corresponding solution: Supply chain: the attacker uses the TRUSTED CHANNEL to enter...

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): Supply chain: the attacker uses the TRUSTED CHANNEL to enter. This highlights that attackers can compromise a trusted vendor or supplier to gain access to the target organization's network, bypassing perimeter defenses because the traffic appears to come from a trusted source. Mitigations include vendor risk management, software bill of materials (SBOM), and supply chain security assessments.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

3) D — Implement the corresponding solution: SolarWinds: the classic case (18k companies)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): SolarWinds: the classic case (18k companies).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: SBOM = Software Bill of Materials — list of software components....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): SBOM = Software Bill of Materials — list of software components. An SBOM provides transparency into the components and dependencies of software, enabling organizations to identify and mitigate supply chain risks such as vulnerable libraries or malicious code.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) D — Implement the corresponding solution: 'list of software components' = SBOM....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): 'list of software components' = SBOM. A Software Bill of Materials (SBOM) is a formal, machine-readable inventory of all components, libraries, and dependencies in a software product, enabling organizations to identify and mitigate supply chain risks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'checks dependencies for known vulnerabilities' = SCA..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): 'checks dependencies for known vulnerabilities' = SCA. Software Composition Analysis (SCA) scans third-party libraries and dependencies for known CVEs, helping mitigate supply chain risks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) C — Implement the corresponding solution: Scenario: compromised npm library affects everyone using the package = supply chain vulnerability....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): Scenario: 'compromised npm library affects everyone using the package' = supply chain vulnerability. A supply chain vulnerability occurs when a component or dependency from an external source is compromised, affecting all downstream users. This matches the scenario.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: Supply chain: the attacker uses the TRUSTED CHANNEL to get in....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): Supply chain: the attacker uses the TRUSTED CHANNEL to get in. Supply chain attacks exploit trusted relationships and channels (e.g., software updates, vendor access) to compromise the target, bypassing perimeter defenses.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting

pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: SolarWinds: the classic case (18k companies)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities): SolarWinds: the classic case (18k companies). The SolarWinds supply chain attack (disclosed in 2020) involved attackers compromising the build process of SolarWinds Orion software and inserting malicious code (a backdoor) into legitimate updates. This allowed the attackers to gain access to approximately 18,000 organizations, including government agencies and Fortune 500 companies. It highlights the risks of supply chain vulnerabilities, the importance of software integrity verification, and the need for robust third-party risk management.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: SBOM = Software Bill of Materials — list of software components..

The correct answer is to implement the corresponding solution: maintain an SBOM (Software Bill of Materials). According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Supply Chain Vulnerabilities), an SBOM is a formal, machine-readable inventory of software components and dependencies, which is essential for identifying and mitigating supply chain risks such as vulnerable third-party libraries. Distractor breakdown: • Temporarily disable audit logs to accelerate system throughput: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • Replace preventive technical controls with informal terms of adherence: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • Allow shared access among administrators using generic credentials: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

